



(GRC) FRAMEWORK IMPLEMENTATION PROPOSAL

Aligned with ISO/IEC 27001:2022 & NIST Cybersecurity Framework 2.0

Abstract

This proposal presents a structured approach to implement an integrated Governance, Risk, and Compliance (GRC) framework aligned with ISO/IEC 27001:2022 and the NIST Cybersecurity Framework 2.0. The engagement covers cybersecurity risk assessment, control gap analysis, policy and procedure development, and audit readiness preparation. The methodology ensures systematic identification of risks, alignment of controls, and measurable governance oversight. Deliverables will enable the organization to achieve improved compliance, structured risk management, and sustainable information security practices.

G-R-C Ops

1. Executive Summary

This proposal presents a structured approach to establish an integrated Governance, Risk, and Compliance (GRC) framework aligned with ISO/IEC 27001:2022 and the NIST Cybersecurity Framework (CSF 2.0).

The objective of this engagement is to:

- Establish an Information Security Management System (ISMS)
- Conduct a comprehensive cybersecurity risk assessment
- Perform ISO 27001 control gap assessment
- Map organizational controls to NIST CSF 2.0 functions
- Develop policies, procedures, and governance structures
- Prepare the organization for audit and compliance readiness

The proposed methodology ensures systematic risk identification, measurable control implementation, and structured governance oversight.

2. Assumptions

Since organizational specifics were not provided, the following assumptions are made:

- Mid-sized organization (200–500 employees)
- Multi-department structure (HR, IT, Finance, Operations)
- Centralized IT infrastructure
- No existing formal ISMS
- Partial security controls implemented but undocumented
- Executive management support available

These assumptions may be adjusted upon clarification.

3. Scope of Work

In Scope

- Cybersecurity-wide Information Security Risk Assessment
- ISO/IEC 27001:2022 Gap Analysis
- NIST CSF Control Mapping
- Risk Register Development
- Risk Treatment Planning
- Policy and Procedure Framework Design
- ISMS Documentation Structure
- Internal Audit Readiness Preparation

Out of Scope

- Technical control deployment
 - Penetration testing or red teaming
 - SOC implementation
 - Infrastructure redesign
-

4. Methodology

The engagement will be executed in five structured phases aligned with ISO 27001 clauses and NIST CSF functions (Govern, Identify, Protect, Detect, Respond, Recover).

Phase 1 – Project Initiation & Governance Establishment (1st Month)

Activities:

- Stakeholder identification
- Definition of ISMS scope
- Governance committee formation
- Communication plan development
- Risk methodology approval

Methodological Approach:

- **Stakeholder identification:** Conduct interviews and workshops to capture all key decision-makers and operational contacts. Use an organizational chart to map influence and responsibilities.
- **ISMS scope definition:** Apply ISO 27001 Annex A and asset mapping to decide which departments, systems, and processes are in scope. Document the scope formally.
- **Governance committee formation:** Define roles and responsibilities; create RACI matrices. Assign authority levels and escalation paths.
- **Communication plan:** Draft a schedule for status meetings, reporting, and stakeholder updates. Use MS Teams/SharePoint for central document sharing.
- **Risk methodology approval:** Select a risk scoring model (Likelihood × Impact), ensure alignment with ISO 27005 and NIST CSF risk principles. Present for management approval.

Deliverables:

- Project Charter
 - Governance Structure Document
 - RACI Matrix
 - Approved Risk Methodology
-

Phase 2 – Current State Assessment (ISO 27001 Gap Analysis) (2nd Month – 3rd Month)

Activities:

- Documentation review
- Stakeholder interviews
- Control maturity assessment
- Annex A control evaluation
- Mapping controls to NIST CSF categories

Methodological Approach:

- **Documentation review:** Collect existing policies, procedures, system configurations, and logs. Assess coverage against ISO 27001 Annex A controls.
- **Stakeholder interviews:** Structured questionnaires to validate current practices, identify undocumented processes.
- **Control maturity assessment:** Rate controls using a 1–5 maturity scale (Initial → Optimized).
- **Annex A evaluation:** Use a checklist to compare current controls vs. ISO 27001 requirements. Identify gaps.
- **NIST CSF mapping:** Map each implemented control to CSF functions and categories using a matrix.

Deliverables:

- Gap Assessment Report
- Control Maturity Matrix
- Compliance Heat Map
- NIST CSF Alignment Matrix

Phase 3 – Cybersecurity Risk Assessment (4th Month – 5th Month)

Methodology aligned with ISO 27005 and NIST Risk Management principles.

Activities:

- Asset identification and classification
- Threat identification
- Vulnerability analysis
- Likelihood and impact scoring
- Risk calculation (Qualitative or Semi-Quantitative)
- Risk prioritization

Methodological Approach:

- **Asset identification & classification:** List all assets, classify by sensitivity (Confidential, Internal, Public).

- **Threat identification:** Catalog potential threats from internal/external sources; reference STRIDE/DREAD.
- **Vulnerability analysis:** Assess systems for known weaknesses using CVE databases, past incidents, and interviews.
- **Likelihood & impact scoring:** Use qualitative (High/Medium/Low) and semi-quantitative scoring (1–5 scale) based on asset value, threat probability, and vulnerability exploitability.
- **Risk calculation:** Apply Risk Score = Likelihood × Impact and Generate heat maps for visualization.
- **Prioritization:** Focus on High & Critical risks for treatment. Use dashboards for visualization.

Deliverables:

- Risk Register (Excel format)
- Risk Heat Map
- Risk Assessment Report

Phase 4 – Risk Treatment & Control Framework Development (6th Month – 7th Month)

Activities:

- Risk treatment decision (Mitigate, Transfer, Accept, Avoid)
- Control selection from ISO 27001 Annex A
- Alignment to NIST CSF 2.0 functions
- Statement of Applicability (SoA) development
- Policy drafting

Policies Developed May Include:

- Information Security Policy
- Risk Management Policy
- Access Control Policy
- Incident Response Policy
- Business Continuity Policy
- Supplier Risk Management Policy

Methodological Approach:

- **Risk treatment decision:** Workshops with management to decide Mitigate/Transfer/Accept/Avoid for each risk. Document rationale.
- **Control selection:** Map each risk to ISO 27001 Annex A control(s) and NIST CSF function(s). Include implementation notes.
- **Statement of Applicability (SoA):** For each control, document status, justification, and implementation plan.
- **Policy drafting:** Follow ISO 27001 standard templates. Each policy should include purpose, scope, roles/responsibilities, procedure references, and review cycle.
- **Validation:** Peer review of policies by compliance analyst and risk analyst.

- **Communication & training:** Conduct sessions for staff to understand new policies and responsibilities.

Deliverables:

- Risk Treatment Plan
- Statement of Applicability
- Policy Framework Pack
- Control Implementation Roadmap

Phase 5 – ISMS Formalization & Audit Readiness (8th Month – 9th Month)

Activities:

- ISMS documentation compilation
- KPI and KRI definition
- Internal audit simulation
- Management review preparation

Methodological Approach:

- **ISMS documentation:** Compile all policies, SoA, risk registers, procedures, and evidence in version-controlled repository (SharePoint/Git).
- **KPI/KRI definition:** Define measurable metrics for control effectiveness (e.g., number of high-risk incidents, time to remediate).
- **Internal audit simulation:** Execute mock audits using ISO 27001 audit checklists. Identify gaps and corrective actions.
- **Management review:** Prepare executive dashboard and summary report with risks, controls, and audit findings.
- **Training & awareness:** Conduct ISMS awareness sessions and tabletop exercises for critical incident response.

Deliverables:

- ISMS Manual
- KPI Dashboard Framework
- Internal Audit Checklist
- Executive Readiness Report

5. Deliverables Summary

- Project Charter
- Governance Framework Document

- Gap Assessment Report
- Risk Register
- Risk Heat Map
- NIST CSF Mapping Matrix
- Statement of Applicability
- Risk Treatment Plan
- Policy Framework Pack
- ISMS Manual
- Audit Readiness Report

All deliverables will be formally structured and version-controlled.

6. Governance Model

The project will operate under the following governance structure:

- **Executive Sponsor:** Overall decision authority.
- **Steering Committee:** Strategic guidance and approvals.
- **GRC Project Lead:** Project execution, risk oversight.
- **Risk Analyst:** Risk assessment, threat modeling.
- **Compliance Specialist:** ISO 27001 & NIST CSF alignment.
- **Policy & Documentation Specialist:** Policy drafting, ISMS compilation.
- **Internal Audit Liaison:** Audit simulation & KPI/KRI monitoring.

Reporting frequency: Monthly status updates and milestone reviews.

7. Timeline

Estimated duration: 10 Months

Phase	Duration	Key Milestones
Initiation & Governance	Month 1	Project Charter, RACI approved
Current State & Threat Modeling	Months 2–3	Gap Report, Threat Map, CSF Mapping
Risk Assessment	Months 4–5	Risk Register, Heat Map, KPIs/KRIs
Risk Treatment & Control Framework	Months 6–7	SoA, Policies Drafted, Control Roadmap
ISMS Documentation & Audit Readiness	Months 8–10	ISMS Manual, Internal Audit Simulation

8. Project Risk Management

Project Risk	Mitigation Strategy
--------------	---------------------

Limited stakeholder engagement	Executive sponsorship
Incomplete documentation	Conduct structured workshops
Scope creep	Strict change management process
Policy resistance	Awareness and management involvement

9. Success Metrics

- 100% ISO 27001 control gap assessment completed
 - Comprehensive Cybersecurity risk register established
 - High and Critical risks identified and treatment plans defined
 - Statement of Applicability formally approved
 - Internal audit simulation completed
 - Documented ISMS framework established
-

10. Value Proposition

This integrated ISO 27001 + NIST CSF approach ensures:

- Structured governance
 - Measurable risk reduction
 - Control transparency
 - Regulatory alignment
 - Audit preparedness
 - Sustainable compliance maturity
-

11. Project Team & Curriculum Vitae

11.1 Project Team Structure

Name	Proposed Role	Responsibility Area
Lubna Aburumman	GRC Lead / ISMS Coordinator	Project leadership, ISO 27001 gap analysis, risk methodology
Hala Rababah	Risk Assessment Analyst	Risk identification, scoring, risk register
Maryam Shajrawi	Compliance & Control Analyst	ISO 27001 Annex A mapping, NIST CSF alignment
Wasan	Policy & Documentation Specialist	Policy drafting, ISMS documentation

Yasmeen Alkafrawi	Internal Audit & Governance Analyst	Internal audit simulation, KPI/KRI framework
------------------------------	--	--

11.2 Curriculum Vitae – Lubna AbuRumman

Proposed

GRC Lead Consultant – ISO 27001 & NIST CSF Implementation

Role:

Professional Summary

Junior GRC Analyst with academic and practical exposure to ISO/IEC 27001:2022 implementation, cybersecurity risk assessment methodologies, and NIST Cybersecurity Framework mapping. Experience in developing structured risk registers, conducting simulated control gap assessments, and designing ISMS documentation frameworks. Strong analytical capability in governance modeling and compliance structuring.

Core Competencies

- ISO/IEC 27001:2022 ISMS Framework
- NIST Cybersecurity Framework (CSF 2.0)
- Cybersecurity Risk Assessment (ISO 27005 aligned)
- Risk Register Development
- Control Gap Analysis
- Statement of Applicability (SoA) Development
- Policy & Procedure Drafting
- Governance & RACI Modeling

Certifications & Training

- Governance, Risk, Compliance, and Data Privacy – IBM
- Vulnerability Management – IBM
- Governance, Risk and Compliance – YGA
- Advanced Data Analytics – Correlation One (*applied for risk data analysis*)

Academic Projects

Risky – Risk Assessment tool

Role: Project lead and Backend Implementer

- Led project governance and execution lifecycle, ensuring structured planning, role allocation, and milestone tracking.
- Designed and implemented backend architecture to support risk identification, scoring, and tracking functionalities.

- Developed risk scoring logic based on likelihood × impact model aligned with ISO 27005 principles and OWASP risk rating methodology.
 - Ensured alignment of the tool's workflow with Cybersecurity risk management best practices.
 - Oversaw adherence to secure development practices and version control standards.
 - Coordinated team members to ensure deliverables met defined functional and documentation requirements.
-

Education

Bachelor's Degree in Information and Cybersecurity - Balqaa Applied University

Relevant Coursework

- Cyber Laws & Ethics
 - Policy Design & Analysis
 - Risk Management
 - Privacy & Data Protection
-

Technical Tools

- Microsoft Excel (Risk Matrix & Heat Maps)
- GRC Documentation Templates
- Risk Scoring Models
- Policy Lifecycle Management Tools

11.3 Curriculum Vitae – Hala Rababah

Proposed Role: Risk Assessment Analyst – ISO 27005 & ISO 27001:2022 Implementation

Professional Summary

Risk Assessment and Cybersecurity professional with practical experience in Cybersecurity risk identification, structured risk analysis, and security control evaluation. Skilled in applying likelihood–impact risk models, aligning technical vulnerabilities with governance requirements, and translating operational findings into structured risk insights. Demonstrates strong analytical capability in bridging technical security assessments with ISO 27001–aligned risk management processes.

Core Competencies

- Cybersecurity Risk Identification & Classification
 - Risk Scoring (Likelihood × Impact Model)
 - Risk Register Development & Maintenance
 - ISO/IEC 27001:2022 Control Mapping
 - Control Gap Analysis
 - Risk Treatment Planning (Mitigate, Transfer, Accept, Avoid)
 - Security Vulnerability Assessment
 - Risk Reporting & Heat Map Development
 - Governance Documentation & Structured Reporting
 - Technical Security Analysis
-

Professional Training & Certifications

- GRC Training Program – Green Circle Company, Jordan (2025)
 - Governance, Risk, Compliance & Data Privacy – IBM
 - Vulnerability Management – IBM
 - Advanced Data Analytics – Correlation One
-

Academic Projects

CyberGuard – Mobile Application Vulnerability Scanner

Role: Project Lead & Backend Implementer

- Engineered a Python-based tool to scan Android APK files for insecure data storage and hardcoded credentials
- Identified vulnerabilities and translated findings into structured technical risk observations

- Automated vulnerability detection and structured report generation
- Applied OWASP-aligned risk reasoning to prioritize findings
- Strengthened understanding of how technical weaknesses translate into organizational risk exposure

Security Monitoring Dashboard

- Developed centralized dashboard to visualize real-time network traffic
 - Assisted in identifying abnormal patterns and potential threat indicators
 - Supported structured incident response analysis through log visualization
 - Enhanced understanding of operational monitoring as an input to risk detection processes
-

Education

Bachelor's Degree in Cyber Security - The University of Jordan – Expected Graduation 2026

Technical Tools

- Microsoft Excel (Risk Matrix, Heat Maps, Reporting)
- Risk Register & ISMS Documentation Templates
- Python (Security Automation & Risk Logic)
- Burp Suite, Wireshark, Nmap
- Linux Environment & Network Analysis Tools

11.4 Curriculum Vitae – Maryam Shajrawi

Proposed Role: Compliance & Control Analyst

Professional Summary

Cybersecurity governance junior specializing in control evaluation and compliance assessment aligned with ISO/IEC 27001:2022 and the NIST Cybersecurity Framework. Experience in performing structured control gap analysis, evaluating policy effectiveness, and translating security documentation into measurable compliance observations and remediation actions.

Core Competencies

- ISO/IEC 27001:2022 Annex A Control Evaluation
 - NIST CSF Function Mapping (Identify–Recover)
 - Control Gap Analysis & Observation Writing
 - Security Policy & Procedure Review
 - Compliance Documentation Structuring
 - Control Maturity Assessment
 - Governance Reporting
-

Project Experience

Cybersecurity Governance Assessment Simulation – Compliance Analyst

- Reviewed organizational security policies, standards, and procedures for ISO/IEC 27001:2022 alignment.
- Conducted Annex A control gap assessment identifying missing and partially implemented controls.
- Evaluated access control, incident management, asset management, and policy governance practices.
- Mapped implemented controls to NIST CSF functions (Identify, Protect, Detect, Respond, Recover)
- Produced structured gap observations and remediation recommendations.
- Developed control maturity matrix and compliance heat map documentation.

Education

Bachelor’s Degree in Network Security Engineering.

11.5 Curriculum Vitae – Wasan

Proposed Role: Policy & Documentation Specialist

Professional Summary

Cybersecurity governance junior specializing in ISMS documentation and policy development aligned with ISO/IEC 27001:2022 standards. Experienced in structuring policies, procedures, and documentation frameworks to support audit readiness and regulatory compliance. Strong focus on translating governance requirements into actionable ISMS deliverables.

Core Competencies

- ISO/IEC 27001:2022 Policy Development
 - Risk Management Policy Drafting
 - Incident Response & Business Continuity Documentation
 - ISMS Manual Structuring & Version Control
 - Compliance Documentation Templates
-

Project Experience

ISMS Documentation Simulation – Policy Specialist

- Drafted comprehensive ISMS manual aligned with ISO 27001:2022 clauses
 - Developed structured supporting policy framework covering Information Security, Risk Management, Access Control, and Business Continuity
 - Established version control and document management procedures for ISMS documents
 - Ensured policies and procedures were mapped to NIST CSF functions where applicable
 - Supported internal audit simulation by preparing structured documentation ready for review
-

Education

Bachelor's Degree in Communications Engineering

11.6 Curriculum Vitae – Yasmeen Alkafrawi

Proposed Role: Internal Audit & Governance Analyst

Professional Summary

Governance and internal audit professional focused on ISO/IEC 27001:2022 compliance and internal audit simulation. Experienced in KPI/KRI development, governance oversight, and preparing organizations for audit readiness. Skilled in translating ISMS requirements into measurable audit outputs and structured reporting.

Core Competencies

- Internal Audit Checklist Development & Execution
 - KPI and KRI Definition & Tracking
 - Compliance Monitoring & Reporting
 - Governance Framework Alignment
 - ISMS Performance Evaluation
 - Audit Readiness Simulation
-

Project Experience

Internal Audit & Governance Simulation – ISMS Analyst

- Designed and executed internal audit simulation aligned with ISO 27001 monitoring and measurement clauses
 - Developed audit readiness checklist to ensure comprehensive review of ISMS policies and procedures
 - Created structured management review templates to summarize audit findings and performance metrics
 - Defined KPIs and KRIs to measure ISMS effectiveness and monitor compliance progress
 - Supported governance oversight by mapping audit outputs to organizational compliance and risk objectives
-

Education

Master's Degree in Digital Business Management

Appendix A – Sample Gap Assessment Output

Control Area	Current Status	Observation	Required Action
Information Security Policy	Available	Needs formal review cycle	Schedule annual review
Access Control	Partially Defined	No detailed procedure	Develop access management procedure
Incident Management	Not Documented	No formal response plan	Create Incident Response Plan
Asset Management	Informal Tracking	No centralized inventory	Establish asset inventory register

Appendix B – Sample NIST CSF Mapping Observation

Function	Status	Observation
Identify	Partial	Asset classification incomplete
Protect	Partial	Access control needs strengthening
Detect	Weak	Monitoring processes not defined
Respond	Missing	No incident response framework
Recover	Limited	Recovery testing not documented